

# Real-World Case Study: Implementing RMF in a Federal Environment

PRACTICAL INSIGHTS, CHALLENGES, AND BEST PRACTICES FOR  
ACHIEVING COMPLIANCE AND SECURITY



GRC GATE TRAINING



# Introduction to RMF Case Study

Exploring real-world implementation of RMF in a federal environment

- Focus on a case study that combines regulatory requirements, technology, and application

Examination of compliance, risk management, and cloud adoption

- Strong emphasis on FISMA and FedRAMP requirements

Uncovering choices, challenges, and lessons learned

- Will guide future practitioners in RMF through each phase of the process

# The Need for Federal Risk Management

## Federal information systems handle sensitive and classified data

- Data ranges from personally identifiable information to secret operations

## FISMA mandates comprehensive security frameworks for all agencies

- Requires United States federal agencies to secure information and systems

## FISMA and FedRAMP depend on NIST guidelines

- FedRAMP standardizes cloud security assessments and continuous monitoring







# Case Study Overview: Agency Cloud Migration

Midsized federal agency modernizing human resources management system

- Transitioning from on-premises legacy to cloud-based FedRAMP solution

Aims to protect sensitive employee data and stay compliant

- Ensures federal mandate compliance and security for employee information

Uninterrupted service delivery to tens of thousands

- Continuous access to records for employees nationwide

# RMF Step 1: Categorization Process

---

## Guided by FIPS Publication 199 for system categorization

- Categorizes based on security breach impact on mission, assets, or people

## Multi-stakeholder group assessed information types and impact

- Information security officers, system owners, and privacy officials collaborated

## Assigned impact ratings: Confidentiality–high, Integrity–moderate, Availability–moderate

- Ratings influenced by risk of identity theft, payroll errors, and access needs





# RMF Step 2: Security Control Selection & Tailoring

## Used NIST SP 800-53 Rev 5 control catalog by families

- Categories include access control, audit/accountability, and incident response

## Baseline controls assigned by impact level; tailored for organizational relevance

- Agency used moderate baseline for confidentiality/availability, high for confidentiality

## Tailoring ensured suitability, documented in system security plan

- Enhanced for threats (e.g., data loss prevention); justified all tailoring actions



# Integrating FedRAMP Requirements

## Selected FedRAMP Moderate authorized cloud provider for compliance

- Ensured standard security assessment and authorization processes

## Reviewed provider's security package and identified shared responsibilities

- Evaluated system security plan, assessment report, and POA&M

## Agency validated and augmented inherited controls

- Conducted extra testing and required provider to align with agency logging/monitoring





# Challenges in RMF Execution

## Control inheritance and shared responsibility posed issues

- Agency discovered backup/recovery responsibilities were not fully managed by provider

## High documentation volume and complexity in authorization phase

- Difficulty maintaining consistency as system and cloud features changed rapidly

## Continuous monitoring demanded advanced tools and new analyst skills

- Needed SIEM solutions and specific cloud security training



# Lessons Learned from Authorization and Monitoring

---

## Ongoing communication with all stakeholders is vital

- Regular meetings clarified control interpretations and resolved issues quickly

## Documentation discipline enhances audit response and understanding

- Kept control inventories, assignments, and artifacts current for efficiency

## Continuous monitoring as a dynamic, risk-informed practice

- Combined automated scanning, log analysis, and red team exercises



# Conclusion and Key Takeaways

RMF implementation demands regulatory attention, control tailoring, and FedRAMP integration

- Each component is essential for federal environment risk management

FIPS 199 and NIST SP 800-53 provide bedrock for risk categorization and control selection

- FedRAMP brings extra complexity and security assurance in cloud

Challenges overcome with communication, automation, and risk culture

- Lessons relevant to both federal agencies and organizations balancing innovation with compliance

